Установка инструментов в Kali Linux

Обновить сведения о пакетах и установить основной набор утилит для анализа файлов и стеганализа можно двумя командами:

```
sudo apt update
sudo apt install libimage-exiftool-perl poppler-utils binwalk p7zip-full foremost steghide hexedit
```

exiftool

Чтение метаданных EXIF, IPTC, XMP

pdfinfo

Свойства и метаданные PDF-документов

binwalk

Поиск сигнатур внутри файлов

7z

Просмотр и извлечение архивов

foremost

File carving по сигнатурам

steghide

Скрытые вложения в JPEG, BMP, WAV, AU

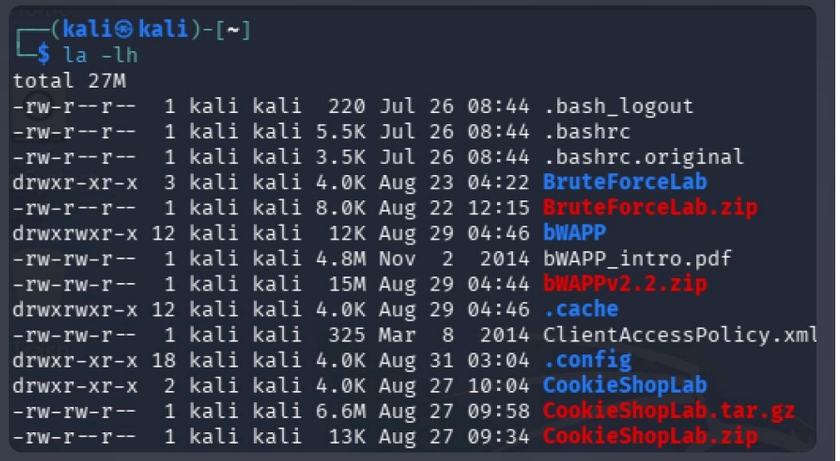
hexedit

Просмотр файла в шестнадцатеричном виде

Проверить доступность всех программ после установки:

```
exiftool -ver && pdfinfo -v && binwalk --help && 7z --help && foremost -V && steghide --version
```

Команда ls: первичный осмотр файлов



Синтаксис

Ключ `-l` добавляет размер, права доступа и дату изменения. Ключ `-h` выводит размер в удобочитаемом виде:

```
ls -lh
```

На что обращать внимание

Необычно **большой размер** изображения или короткой аудиозаписи — один из первых признаков дополнительных данных внутри файла.

Например, PNG-иконка в несколько мегабайт или короткий WAV-клип размером 50 МБ заслуживают немедленной проверки остальными инструментами.

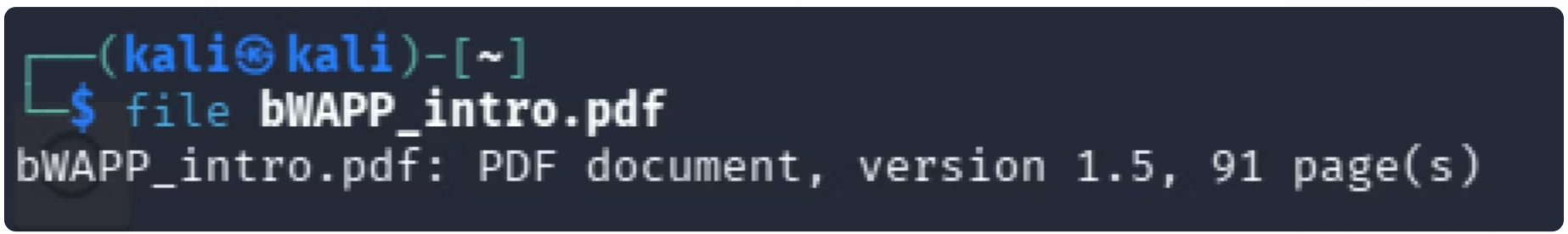
Расширение файлов

Расширение файла не гарантирует, что перед нами действительно изображение, PDF или аудиозапись. Команда `file` определяет формат по **сигнатуре содержимого**, а не по имени файла:

```
file image.jpg
```

Сразу проверить все файлы в текущей директории:

```
file *
```



Сигнатуры форматов и интерпретация результата

Сравните расширение с результатом

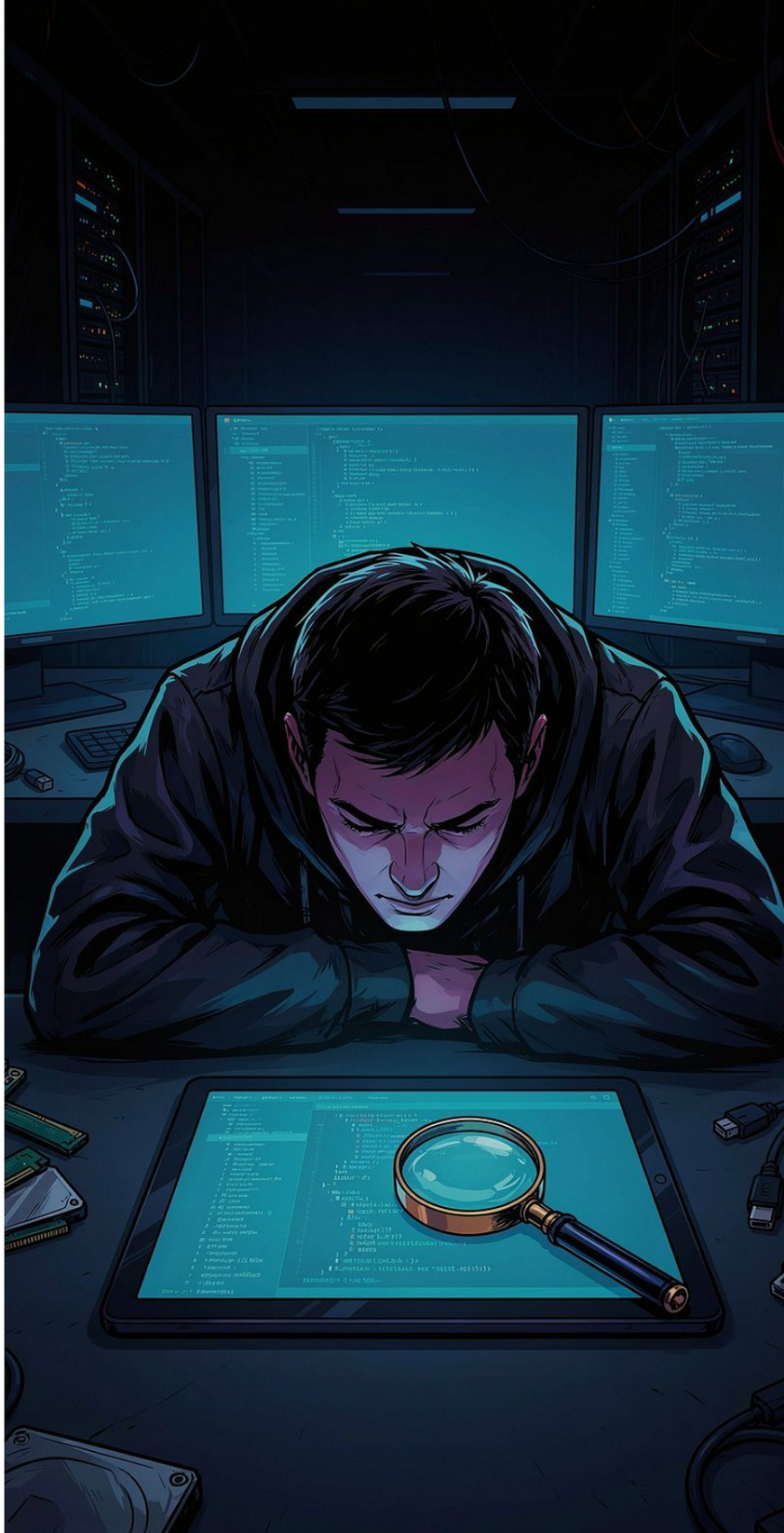
Если `file` сообщает, что `image.jpg` — это на самом деле ZIP-архив, это прямая улика.

Обратите внимание на детали

Разрешение изображения, версия PDF, параметры аудио и упоминание архивных данных — всё это важная информация для дальнейшего анализа.

Сигнатуры форматов

JPEG начинается с `FF D8 FF`, PNG — с `89 50 4E 47`, PDF — с `25 50 44 46` (`%PDF`), ZIP — с `50 4B 03 04` (`PK`).



exiftool: просмотр метаданных

Метаданные — служебные сведения о файле: автор, комментарий, модель камеры, координаты, время создания. В CTF в одно из этих полей часто помещают подсказку или флаг.

Основные команды

```
exiftool image.jpg
exiftool -s image.jpg
exiftool -Comment -Description -Title -Subject -Artist image.jpg
```

Поиск интересных строк без учёта регистра:

```
exiftool image.jpg | grep -Ei 'comment|description|title|subject|author|flag|ctf'
```

exiftool: расширенный просмотр

exiftool читает не только EXIF, но и IPTC, XMP и метаданные PDF.

- → -a — Показать повторяющиеся поля
- → -u — Показать неизвестные поля
- → -g1 — Сгруппировать по типу метаданных

```
exiftool -a -u -g1 protected.jpg
```

pdfinfo: свойства PDF-документа

Команда

```
pdfinfo document.pdf
```

Показывает основные сведения о PDF: заголовок, тему, автора, программу-создатель, даты, число страниц и размер листа.

Совет

Поле `Creator` может раскрыть оригинальную программу (например, LibreOffice или Microsoft Word), что иногда является подсказкой в условии задания.

Когда pdfinfo недостаточно

Часть сведений может храниться в **XMP-метаданных**, которые pdfinfo не всегда отображает. В таком случае используйте exiftool:

```
exiftool -a -u -g1 document.pdf
```

Используйте оба инструмента в связке: pdfinfo даёт быстрый обзор, exiftool — полную картину скрытых полей.

strings: поиск читаемого текста

Файлы изображений и аудиозаписей в основном состоят из двоичных данных, но внутри них могут встречаться читаемые строки. Утилита `strings` извлекает такие последовательности символов.

Основные команды

```
strings image.png
strings -a -n 6 image.png
```

Ключ `-a` просматривает весь файл, `-n` задаёт минимальную длину строки.

Фильтрация результатов

```
strings -a image.png | grep -Ei
'ctf|flag|pass|secret|zip'
strings -a image.png | tail -n 30
```

strings: что искать в выводе

После запуска strings обратите внимание на следующие признаки в выводе:

- Имена файлов (особенно с расширениями .txt, .zip, .py)
- Признаки архива: строки PK, пути к файлам внутри архива
- Фрагменты текста или закодированные строки (Base64, hex)
- Любые осмысленные слова, не характерные для данного формата

strings не извлекает вложение автоматически. Он помогает обнаружить признаки архива — после чего применяйте binwalk или 7z.

binwalk: поиск данных внутри файла

binwalk ищет внутри файла сигнатуры известных форматов. Например, в конце обычного изображения может находиться ZIP-архив, а после данных WAV — архив tar.gz.

```
binwalk image.png
binwalk audio.wav
```

DECIMAL	HEXADECIMAL	DESCRIPTION
Смещение в байтах от начала файла	То же смещение в шестнадцатеричном виде	Предполагаемый тип найденных данных

binwalk: извлечение вложений

Сигнатура по ненулевому смещению — признак вложения. Автоматическое извлечение:

```
binwalk -e image.png
sudo binwalk -e --run-as=root image.png
```

После извлечения появится директория _image.png.extracted. Осмотрите её содержимое:

```
find _image.png.extracted -maxdepth 2 -type f -print
file _image.png.extracted/*
```

7z: просмотр и извлечение архивов

Команды

Посмотреть содержимое без извлечения:

```
7z l image.png
7z l audio.wav
```

Извлечь найденные данные в отдельную директорию:

```
mkdir extracted_data
7z x image.png -oextracted_data
```

После извлечения проверить содержимое:

```
find extracted_data -type f -maxdepth 2 -print
file extracted_data/*
```

Особенности 7z

Программа умеет определять и открывать многие архивные форматы. Иногда она может найти архив, даже если тот **дописан к изображению или аудиофайлу** — там, где другие инструменты могут не сработать.

Предупреждение о данных

Сообщение о данных *до или после архива* в учебном задании — не обязательно ошибка. Это может быть указанием на объединение двух файлов (техника **file concatenation**). Изучите смещение и проверьте обе части.

foremost: извлечение по сигнатурам

foremost выполняет **file carving** — ищет начало и конец известных типов файлов и сохраняет найденные объекты. Инструмент полезен, если binwalk обнаружил данные, но не смог их извлечь автоматически.

```
foremost -i audio.wav -o foremost_output
```

Параметр `-i`

Задаёт исследуемый файл-источник для анализа

Параметр `-o`

Задаёт новую директорию для результатов. Директория не должна существовать заранее или должна быть пустой

Просмотр результата

После завершения проверьте извлечённые файлы командой `find foremost_output -type f -print`

foremost особенно хорошо работает с распространёнными форматами (JPEG, PNG, PDF), но может не распознать каждый тип архива. Используйте его в связке с binwalk.

Шестнадцатеричный редактор

Hex-редактор показывает **реальные байты файла**: слева — смещение, в центре — байты в hex, справа — текстовое представление. Это позволяет вручную проверить структуру файла и найти сигнатуры.

```
hexedit image.png
```

Формат	Сигнатура (hex)	Текстовое представление
JPEG	`FF D8 FF`	—
PNG	`89 50 4E 47 0D 0A 1A 0A`	`.PNG....`
PDF	`25 50 44 46`	`%PDF`
ZIP	`50 4B 03 04`	`PK..`
GZIP	`1F 8B`	—
WAV	`52 49 46 46 ... 57 41 56 45`	`RIFF....WAVE`

Если binwalk сообщил, что вложение начинается со смещения 12345 — используйте `dd` для извлечения (12345 — пример, используйте реальное значение из вывода binwalk):

```
dd if=image.png of=embedded.bin bs=1 skip=12345 status=progress
file embedded.bin
```

steghide: скрытые вложения в JPEG и WAV

steghide встраивает данные внутрь JPEG, BMP, WAV или AU. Содержимое может быть защищено парольной фразой, а обычный просмотр изображения не показывает наличия вложения.

Информация о контейнере

```
steghide info container.jpg
```

Извлечение с пустой парольной фразой

```
mkdir extracted_open
cd extracted_open
steghide extract -sf ../container.jpg -p ''
ls -la && file *
cd ..
```

Извлечение с известным паролем

```
mkdir extracted_protected
cd extracted_protected
steghide extract -sf ../protected.jpg -p
'<парольная_фраза>'
```



steghide: где искать пароль?

Если steghide запрашивает пароль, проверьте следующие источники перед перебором:

1. **В условии задания**

   Часто пароль спрятан прямо в описании или названии задачи

2. **В метаданных файла**

   Перед перебором всегда выполните `exiftool -a -u -g1 protected.jpg`

3. **В визуальном содержимом**

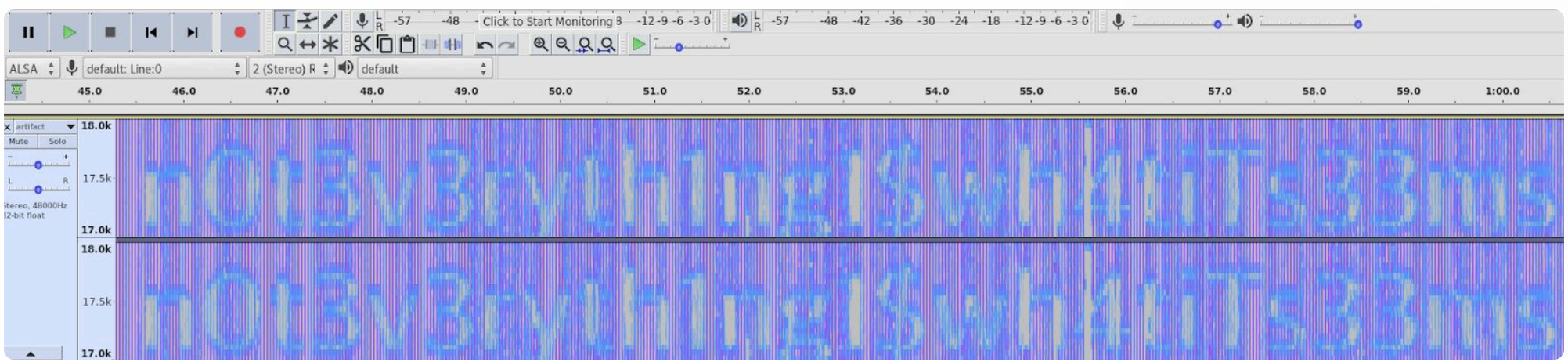
   Надпись на изображении, текст в кадре или стеганографически скрытый текст

Audacity и Sonic Visualiser

Аудиофайл можно открыть в Audacity или Sonic Visualiser и изучить форму сигнала и спектрограмму. Информация может быть скрыта в частотах, паузах, отдельных каналах или необычных звуках.

Работа в Audacity

Спектрограмма включается через меню дорожки: **Waveform → Spectrogram**. После этого стоит изменить масштаб и параметры окна, чтобы увидеть скрытые изображения или текст в частотном спектре.



Спектр vs. вложение

Умение различить два случая экономит много времени при анализе.

Спрятано в спектре

Файл имеет нормальный размер, но при отображении спектрограммы видны буквы, QR-код или изображение.

Архив дописан

Файл непропорционально большой, binwalk находит сигнатуру по ненулевому смещению.

Пример **https://blog.welcomethrill.house/2018/04/the-audacity-of-some-ctfs.html**

Универсальный алгоритм анализа файла

Для большинства начальных заданий применяйте следующую последовательность обзорных команд перед выбором специализированного инструмента:

```
ls -lh <файл>
file <файл>
exiftool -a -u -g1 <файл>
strings -a <файл> | tail -n 30
binwalk <файл>
7z l <файл>
```



Выбор следующего инструмента определяется результатами: интересные метаданные → exiftool/pdfinfo; сигнатура архива → binwalk -e, 7z x или dd; файл для steghide → steghide info; ничего не найдено → hexedit; подозрительный звук → Audacity.

Выбор инструмента по признакам файла

Эта таблица определяет направление анализа, но не заменяет изучение условия. Формулировка и необычные слова часто подсказывают, какой инструмент применить первым.

Наблюдение	Что проверить	Подходящие инструменты
В условии упомянуты автор, свойства или комментарий	Служебные поля и метаданные	`exiftool`, `pdfinfo`
Файл заметно больше ожидаемого	Дополнительные или дописанные данные	`binwalk`, `7z`, `foremost`
В двоичном файле могут быть читаемые подсказки	Текстовые последовательности	`strings`, `grep`
Сигнатура по ненулевому смещению	Вложенный объект	`binwalk -e`, `7z x`, `dd`
JPEG или WAV выглядит нормально, но условие говорит о скрытом содержимом	Стеганографический контейнер	`steghide`
В аудио слышны или видны необычные элементы	Форма сигнала и частотный спектр	Audacity, Sonic Visualiser
Автоматические средства не дали результата	Структура и сигнатуры вручную	`hexedit`

Частые ошибки

1 **Ориентироваться только на расширение**

Реальный формат всегда стоит проверить командой `file`. Файл `secret.jpg` может оказаться ZIP-архивом.

2 **Сразу запускать перебор пароля**

Сначала изучите условие, метаданные и содержимое файла — пароль часто лежит на поверхности.

3 **Открывать двоичный файл текстовым редактором**

Для этого предназначены `strings` и hex-редактор, а не nano или gedit.

4 **Извлекать файлы в ту же директорию**

Создавайте отдельную папку для каждого результата, чтобы не путать оригинал с извлечёнными данными.

5 **Игнорировать смещение в выводе binwalk**

Ненулевое смещение показывает, где начинается другой объект — это ключевая информация для `dd`.

6 **Запускать найденные файлы без проверки**

Сначала определите тип через `file`. Неизвестные исполняемые файлы запускать не следует.

Итог

> Основной навык при решении заданий по стеганографии — не знание одной специальной команды, а **последовательный и методичный анализ**.

1. **Обзор**

   `file`, `ls`, `exiftool`, `strings` — безопасные инструменты первичного осмотра

2. **Обнаружение и извлечение**

   `binwalk`, `7z`, `foremost`, `steghide` — поиск и извлечение скрытых данных

3. **Ручной анализ**

   `hexedit`, `dd`, Audacity — проверка гипотез и понимание структуры файла

Читайте условие задания внимательно: формулировка, необычные слова, название файла и его размер часто прямо указывают, какой инструмент применить первым. Этот набор команд и логика их применения охватывают большинство начальных CTF-заданий по стеганографии и анализу файлов.

